

eRakun — Dokumentacija projekta

Kolegij: Razvoj IT rješenja

Alan Bubalo

lipanj 2026.

Sažetak

eRakun je REST API aplikacija u Laravelu koja oponaša rad **informacijskog posrednika** (access pointa) u hrvatskoj **Fiskalizaciji 2.0**. Pokriva cijeli **4-corner** tijekom razmjene eRačuna: prijem računa od ERP-a, generiranje i parsiranje **UBL 2.1 / HR-CIUS** dokumenata, **pravo digitalno potpisivanje i verifikaciju** na dva sloja (XAdES-B na dokumentu, WS-Security na transportu) s vlastitim testnim PKI-jem, **fiskalizaciju** prema mock CIS-u sa sravnjivanjem prijave te **AS4** razmjenu između dva posrednika s otkrivanjem primatelja preko AMS/MPS-a. Projekt je izrađen kao **edukacijska vježba**: vjerno oponaša arhitekturu, formate i tokove poruka certificiranog posrednika, dok su vanjski sustavi (Porezna/CIS, drugi posrednik, nacionalni adresar) i korijeni povjerenja **simulirani**. Dokument opisuje domenski kontekst, arhitekturu, use case-ove, model podataka, API i sigurnosni (PKI) sloj, sve izvedeno iz stvarnog koda.

Sadržaj

Sažetak	1
1 Uvod	3
1.1 Što je eRakun	3
1.2 Kontekst — Fiskalizacija 2.0	3
1.3 Opseg i ograničenja	3
1.4 Tehnološki stog	4
2 Domenski kontekst	5
2.1 Pojmovnik	5
2.2 4-corner model	5
2.3 Standardi i protokoli	6
3 Arhitektura sustava	6
3.1 Dvije aplikacije	6
3.2 Slojevi i obrasci	6

3.3	Tijek izlaznog računa (high-level)	7
3.4	Stanja i prijelazi	8
3.5	Konfiguracija i zamjenjivost (DI)	8
4	Use case-ovi	8
4.1	A. Registar i postavljanje	9
4.2	B. Izlazni račun	11
4.3	C. Ulazni račun	15
5	Model podataka	17
5.1	ER dijagram	18
5.2	parties — stranke	19
5.3	invoices — računi	19
5.4	invoice_lines — stavke računa	19
5.5	fiscal_messages — fiskalne poruke (CIS)	20
5.6	as4_messages — AS4 poruke (transport)	20
5.7	certificates — potpisni certifikati stranaka	21
6	API referenca	21
6.1	POST /api/parties — registracija stranke	21
6.2	GET /api/parties/{party} — dohvat stranke	22
6.3	POST /api/parties/{party}/certificates — učitavanje certifikata	22
6.4	GET /api/parties/{party}/certificates — lista certifikata	23
6.5	DELETE /api/parties/{party}/certificates/{certificate} — opoziv	23
6.6	GET /api/mps/participants/{oib} — MPS discovery	23
6.7	POST /api/invoices — kreiranje izlaznog računa	23
6.8	GET /api/invoices — lista i filtriranje	24
6.9	GET /api/invoices/{invoice} — dohvat računa	24
6.10	GET /api/invoices/{invoice}/xml — UBL XML	25
6.11	PATCH /api/invoices/{invoice}/status — prijelaz statusa	25
6.12	Fiskalizacija i dostava (ručno / retry)	25
6.13	Prijem računa i AS4	26
6.14	Oblik validacijske greške	26
7	Sigurnost i PKI	26
7.1	Dva sloja potpisa (kao u PEPPOL-u)	26
7.2	Testni PKI (TestPkiGenerator)	26

7.3	Potpisivanje UBL-a (<code>InvoiceSigner</code> , <code>XAdES-B</code>)	27
7.4	Potpisivanje AS4 envelopea (<code>As4EnvelopeSigner</code> , <code>WS-Security</code>)	27
7.5	Verifikacija (<code>SignatureVerifier</code>)	27
7.6	Trust store (<code>TrustStore</code>)	28
7.7	Razrješavanje potpisnih vjerodajnica (<code>PartySigningCredentials</code>)	28
7.8	Sažetak sigurnosnih svojstava	28
8	Zaključak i ograničenja	28
8.1	Što projekt postiže	28
8.2	Svjesna ograničenja	29
8.3	Mogući budući rad	29
9	Dodatak: pokretanje i testiranje	29
10	Literatura i izvori	30

1 Uvod

1.1 Što je eRakun

eRakun je aplikacija (REST API) napisana u **Laravelu (PHP)** koja oponaša rad **informatičkog posrednika** u sustavu hrvatske **Fiskalizacije 2.0**. Posrednik je certificirani poslužitelj (*access point*) koji stoji između poslovnih subjekata i Porezne uprave te omogućuje elektroničku razmjenu računa (**eRačuna**) i njihovo prijavljivanje državi.

Projekt je izrađen kao **edukacijska vježba**: cilj je razumjeti i implementirati stvarne tokove poruka, formate i protokole sustava eRačuna, a ne pustiti sustav u produkciju. Zato su sve vanjske strane oponašane (vidi 1.3).

1.2 Kontekst — Fiskalizacija 2.0

Od **1. siječnja 2026.** hrvatski zakon o Fiskalizaciji 2.0 obvezuje sve obveznike PDV-a na elektroničku razmjenu računa u B2B i B2G prometu. Umjesto izravne razmjene PDF-ova ili papira, računi se izmjenjuju kao **strukturirani XML dokumenti** kroz mrežu certificiranih posrednika, a paralelno se prijavljuju (**fiskaliziraju**) Poreznoj upravi. eRakun implementira upravo ulogu jednog takvog posrednika.

1.3 Opseg i ograničenja

Projekt implementira **funkcionalnu jezgru** posrednika:

- prijem računa od ERP sustava (REST API, „unutarnji rub”)
- generiranje i parsiranje **UBL 2.1** dokumenata s hrvatskim ekstenzijama
- **digitalno potpisivanje** i **verifikaciju** potpisa (pravi kriptografski potpis, vlastiti testni PKI)

- **fiskalizaciju** prema mock CIS-u (Porezna)
- razmjenu računa s drugim posrednikom preko **AS4** protokola
- **otkrivanje primatelja** (discovery) preko mock nacionalnog adresara (AMS/MPS)

Svjesno **nije** u opsegu (oponašano ili pojednostavljeno):

- prava Porezna uprava — zamijenjena companion aplikacijom **erakun-porezna** (mock CIS)
- pravi certifikati FINA-e / OpenPEPPOL-a — zamijenjeni vlastitim **testnim PKI-jem**
- puni set eReporting poruka (plaćanja, odbijanja) — implementirana je samo osnovna fiskalizacija računa (**FiscalMessageType::Fis**), ostali tipovi su predviđeni ali zakomentirani
- autentikacija/autorizacija ERP klijenata, rate-limiting, multi-tenancy

1.4 Tehnološki stog

Sloj	Tehnologija
Jezik / framework	PHP 8.2+, Laravel 12
Baza podataka	relacijska (Eloquent ORM, migracije); SQLite u razvoju
Format računa	UBL 2.1 XML (DOM manipulacija)
Kriptografija	OpenSSL, robrichards/xmlseclibs (XML-DSig / XAdES)
Transport (posrednik↔posrednik)	AS4 (ebMS 3.0) preko HTTP-a
Testiranje	Pest; statička analiza Larastan/PHPStan; Rector; Pint

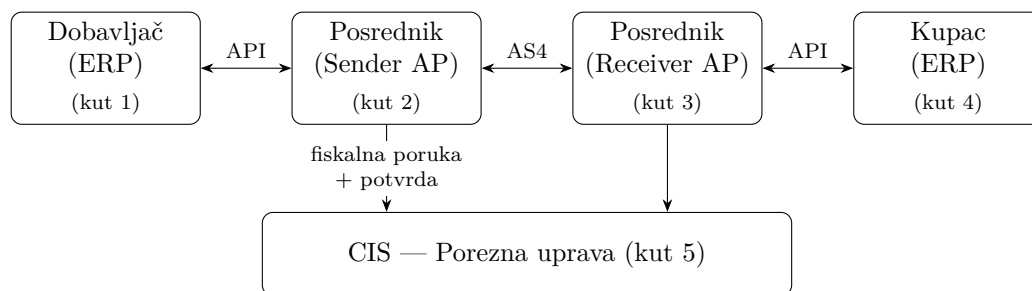
2 Domenski kontekst

2.1 Pojmovnik

Pojam	Značenje
Informacijski posrednik	Certificirani access point koji šalje/prima eRačune i fiskalizira ih. Uloga koju glumi eRakun.
eRačun	Strukturirani elektronički račun (UBL 2.1 XML), pravno ekvivalentan papirnatom.
Fiskalizacija	Prijava računa Poreznoj upravi (CIS); obje strane (dobavljač i kupac) prijavljuju isti račun, a CIS provodi uparivanje (matching) i vraća potvrdu.
CIS	Centralni informacijski sustav Porezne uprave. U projektu: mock erakun-porezna .
Party (strana)	Poslovni subjekt — dobavljač (<i>supplier</i>) ili kupac (<i>buyer</i>). Identificiran OIB-om.
OIB	Osobni identifikacijski broj — 11 znamenki, kontrolna znamenka po ISO 7064 (MOD 11,10).
UBL 2.1	Universal Business Language — XML standard za poslovne dokumente.
HR-FISK 2.0 / HR-CIUS	Hrvatska prilagodba (<i>Core Invoice Usage Specification</i>) standarda EN 16931.
EN 16931	Europska norma za elektroničko fakturiranje (semantički model računa).
KPD 2025	Klasifikacija proizvoda po djelatnostima — 6-znamenkasti kôd na svakoj stavci računa.
AS4	Protokol za sigurnu B2B razmjenu poruka (ebMS 3.0); transport između posrednika.
AMS / MPS	Adresar metapodatkovnih servisa / Metapodatkovni servis — nacionalni imenik za otkrivanje endpointa primatelja po OIB-u.

2.2 4-corner model

Razmjena eRačuna odvija se kroz **četiri ugla** (peti je Porezna). Pošiljalac nikad ne šalje izravno primatelju — sve ide preko posrednika:



- **Kut 1 — Dobavljač (ERP):** izdaje račun, šalje ga svom posredniku preko REST API-ja.
- **Kut 2 — Posrednik pošiljalac (Sender AP):** validira, potpisuje i pretvara račun u UBL; fiskalizira ga prema CIS-u; otkriva primateljev posrednik i šalje ga preko AS4.

- **Kut 3 — Posrednik primatelj (Receiver AP):** prima AS4 poruku, raspakira UBL, (po potrebi) fiskalizira sa svoje strane i dostavlja kupcu.
- **Kut 4 — Kupac (ERP):** preuzima zaprimljeni račun preko API-ja.
- **Kut 5 — CIS / Porezna:** prima fiskalne poruke, provodi uparivanje i vraća potvrdu s identifikatorom poruke.

eRakun je **jedna aplikacija koja pokriva i kut 2 i kut 3** — ista instanca može biti pošiljatelj za jedne i primatelj za druge račune. Za demonstraciju punog round-tripa pokreću se **dvije instance** eRakuna (sender + receiver).

2.3 Standardi i protokoli

Komponenta	Standard
Format računa	UBL 2.1 + hrvatske ekstenzije (HR-FISK 2.0 CIUS)
Semantički model	EN 16931-1:2017
Transport posrednik↔posrednik	AS4 (ebMS 3.0 / AS4 profil)
Digitalni potpis	Kvalificirani certifikati s OIB-om, XAdES-B vremenske oznake
Klasifikacija proizvoda	KPD 2025 (6-znamenasti kôdovi)
Otkrivanje adrese	AMS (adresar) + MPS (metapodaci)

3 Arhitektura sustava

3.1 Dvije aplikacije

Aplikacija	Uloga
erakun (ovaj repozitorij)	Informacijski posrednik. Pokriva kut 2 i kut 3. Sadrži i MPS (vlastiti metapodatkovni servis).
erakun-porezna (companion)	Oponaša državne servise: CIS (prima fiskalne poruke, vraća potvrdu s identifikatorom poruke <code>service_message_id</code>) i AMS (nacionalni adresar za discovery).

Komunikacija eRakun → Porezna ide preko HTTP-a; svaki vanjski servis sakriven je iza sučelja (interface) pa je mock zamjenjiv pravim sustavom bez promjene domenskog koda.

3.2 Slojevi i obrasci

Projekt slijedi Laravel konvencije uz dvije svjesne odluke o stilu:

(a) **Kontroleri izlažu samo REST.** Svaki kontroler ima samo standardne resource metode (`index`, `show`, `store`, `update`, `destroy`). Domenske radnje koje nisu čisti CRUD dobivaju **vlastiti kontroler** (npr. `InvoiceFiscalizationController@store`, `InvoiceDeliveryController@store`) umjesto proizvoljnih metoda na jednom kontroleru.

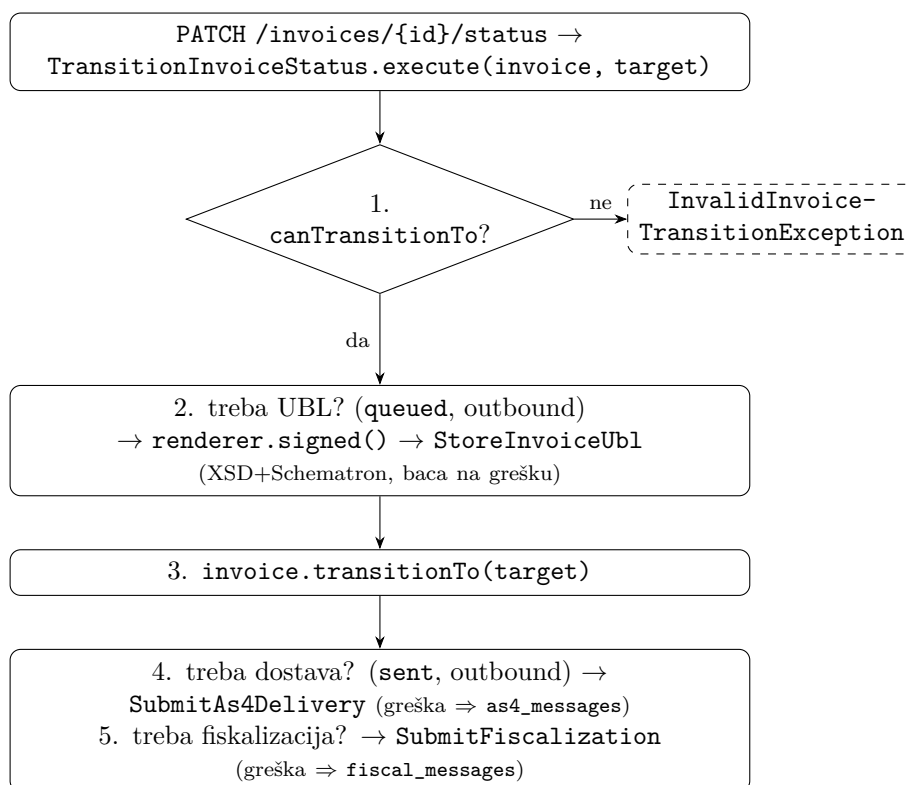
(b) **Poslovna logika živi u Action klasama.** Kontroleri su tanki — validiraju ulaz i delegiraju na **Action** klasu (`app/Actions/`) koja izvodi radnju. Primjeri: `CreateInvoice`, `TransitionInvoiceStatus`, `SubmitFiscalization`, `SubmitAs4Delivery`, `ReceiveInbound`, `ReceiveAs4Message`.

Gruba podjela odgovornosti po direktorijima:

Direktorij	Odgovornost
app/Http/Controllers	Tanki REST kontroleri
app/Http/Requests	Validacija ulaza (form requests)
app/Http/Resources	Oblikovanje JSON odgovora
app/Actions	Poslovne radnje (domenska jezgra)
app/Models	Eloquent modeli + invarijante stanja
app/Enums	Stanja, smjerovi, tipovi (vidi 3.4)
app/Validation	UBL XSD/Schematron validacija (UblValidator)
app/Pki	Generiranje testnog PKI-ja, potpisne vjerodajnice, trust store
app/As4	AS4 transport (envelope build/sign, dostava, prijem, peer discovery)
app/Fiscalization	Klijent prema CIS-u, DTO-ovi odgovora, sravnjivanje
app/Rules	Domenska validacijska pravila (npr. 0ib)

3.3 Tijek izlaznog računa (high-level)

Središnja orkestracija je **TransitionInvoiceStatus** — jedini siguran put za mijenjanje statusa računa. On prvo provjeri je li prijelaz dopušten, zatim (po potrebi) **renderira i potpiše UBL prije** promjene statusa (tako neispravan dokument ostavlja račun u zatečenom stanju), i tek onda okida side-effecte:



Ključna projektna odluka: **dostava i fiskalizacija su odvojene (decoupled)**. Ako AS4 dostava ili fiskalizacija ne uspiju, prijelaz statusa se **ne poništava** — greška se trajno zapiše na pripadni red (`as4_messages` / `fiscal_messages`) i izloži kroz API, a pozivatelj radnju ponovi preko `POST /invoices/{id}/deliver` odnosno `POST /invoices/{id}/fiscalize`.

3.4 Stanja i prijelazi

Domena je modelirana kroz enume — svaki entitet ima **stanje**, neki i **smjer**:

Enum	Vrijednosti	Uloga
InvoiceStatus	draft → queued → sent → received → delivered / rejected	Životni ciklus računa
InvoiceDirection	outbound, inbound	Šaljemo li ga ili primamo
FiscalMessageState	requested → accepted / error	Ishod fiskalizacije
FiscalMessageType	fis (+ predviđeni fis_payment, fis_reject, fis_ir)	Vrsta fiskalne poruke
As4MessageState	queued → sent → acknowledged → received → delivered / error	Stanje AS4 prijenosa
As4MessageDirection	outbound, inbound	Smjer AS4 poruke
MatchStatus	pending → matched / mismatch	Sravnjivanje pošiljatelj/primatelj fiskalizacije
CertificateStatus	active, superseded, revoked	Stanje potpisnog certifikata stranke
VatCategory	S (standard), Z (nulta stopa), E (oslobođeno)	PDV kategorija stavke

Dopušteni prijelazi definirani su na enumu `InvoiceStatus` (`allowedTransitions` / `canTransitionTo`), a `Invoice::transitionTo` je čuvani ulaz koji delegira na enum; detaljna matrica prijelaza dokumentirana je u poglavlju 4.

3.5 Konfiguracija i zamjenjivost (DI)

Sve vanjske ovisnosti registrirane su kao singletoni u `AppServiceProvider` i sakrivene iza sučelja, pa je mock zamjenjiv pravim servisom samo promjenom konfiguracije:

- `FiscalizationService` → `HttpFiscalizationService` (URL/timeout iz `services.fiscalization`)
- `As4DeliveryService` → `HttpAs4DeliveryService` (envelope builder + signer + peer resolver)
- `PeerEndpointResolver` → `AmsMpsPeerEndpointResolver` s **fallbackom** na `ConfigPeerEndpointResolver` (statička mapa `OIB=URL` iz konfiguracije) — discovery prvo pokušava AMS, pa padne na lokalnu mapu
- PKI: `TestPkiGenerator`, `AccessPointCredential`, `TrustStore` (vjeruje dvama testnim korijenima — „FINA-like” za stranke i „PEPPOL-like” za access pointe)

4 Use case-ovi

Ovo je središnje poglavlje. Use case-ovi su grupirani u tri cjeline:

- **A. Registar i postavljanje** — onboarding stranaka, potpisni certifikati, otkrivanje primatelja
- **B. Izlazni račun** — kreiranje, životni ciklus, UBL, fiskalizacija, AS4 dostava
- **C. Ulazni račun** — prijem iz ERP-a, prijem preko AS4, sravnjivanje

Svaki use case opisan je predloškom: **akteri**, **preduvjeti**, **glavni tok**, **posljedice/side-effecti**, te **alternativni tokovi i greške**. Tokovi su izvedeni iz stvarnog koda (Action klase, kontroleri, modeli), ne iz razvojnih bilješki.

Akteri u sustavu

- **ERP dobavljača / kupca** — vanjski sustav koji preko REST API-ja komunicira s posrednikom.
- **Administrator posrednika** — onboarda stranke i učitava certifikate.
- **Drugi posrednik (peer access point)** — šalje/prima AS4 poruke.
- **CIS (Porezna)** — prima fiskalne poruke, provodi uparivanje, vraća potvrdu s identifikatorom poruke. (mock: **erakun-porezna**)
- **AMS (nacionalni adresar)** — imenik za otkrivanje endpointa. (mock: **erakun-porezna**)

4.1 A. Registar i postavljanje

Prije nego što i jedan račun može proteći kroz sustav, posrednik mora poznavati **stranke** (dobavljače i kupce) i imati njihove **potpisne certifikate**. Ova cjelina pokriva i **otkrivanje** (discovery) — kako jedan posrednik pronalazi gdje dostaviti račun za zadani OIB.

4.1.1 UC-A1 — Registracija stranke (onboarding)

Akteri	Administrator posrednika / ERP
Cilj	Upisati poslovni subjekt (dobavljača ili kupca) u registar posrednika.
Endpoint	POST /parties
Kod	PartyController@store → RegisterParticipant

Preduvjeti: nijedan (osim valjanog tijela zahtjeva).

Glavni tok:

1. ERP/administrator šalje podatke o stranci: **oib**, **name**, **address_line**, **city**, **postcode** (5 znakova), opcionalno **is_vat_registered**, **country_code** (2 znaka), **iban**.
2. **StorePartyRequest** validira ulaz: **OIB se provjerava pravilom Oib** (11 znamenki + kontrolna znamenka ISO 7064, MOD 11,10) i mora biti **jedinstven** (**unique:parties,oib**).
3. Stranka se kreira u tablici **parties**.
4. **Najava u AMS-u:** **RegisterParticipant** objavljuje stranku u nacionalnom adresaru kao mapiranje OIB → MPS base URL ovog posrednika, kako bi drugi posrednici znali da mi opslužujemo taj OIB.
5. Vraća se 201 **Created** s **PartyResource** prikazom stranke.

Posljedice: novi red u **parties**; (po uspjehu) zapis u AMS-u da ovaj posrednik opslužuje dati OIB.

Alternativni tokovi i greške:

- Nevaljan/duplikat OIB ili nedostajuća polja → 422 **Unprocessable Entity** (Laravel validacija).
- **AMS najava je best-effort:** ako MPS base URL nije konfiguriran (**RegisterParticipant** vrati **false**) ili je AMS nedostupan, onboarding **svejedno uspijeva** — registracija stranke se ne poništava zbog neuspjele najave.

4.1.2 UC-A2 — Dohvat stranke

Akteri	ERP / administrator
Cilj	Dohvatiti podatke o registriranoj stranci.
Endpoint	GET /parties/{party}
Kod	PartyController@show

Glavni tok: dohvat stranke po identifikatoru i povrat PartyResource prikaza (id, oib, name, adresa, is_vat_registered, country_code, iban). Nepostojeća stranka → 404.

4.1.3 UC-A3 — Učitavanje potpisnog certifikata stranke

Akteri	Administrator posrednika
Cilj	Registrirati certifikat kojim se potpisuju dokumenti u ime stranke (dokumentni sloj).
Endpoint	POST /parties/{party}/certificates
Kod	CertificateController@store → StoreCertificate

Preduvjeti: stranka postoji.

Glavni tok:

1. Administrator šalje certifikat na jedan od dva načina (StoreCertificateRequest):
 - **datoteka certificate** — PKCS#12 (.p12/.pfx, do 50 MB), ili
 - polje **certificate_pem** — PEM string koji nosi certifikat (po želji i privatni ključ),
 - uz opcionalni **password**.
2. StoreCertificate.normalize() prepoznaje format (binarni PKCS#12 vs. PEM s ---BEGIN--- omotom) i **normalizira na PEM**, izdvajajući privatni ključ i certifikat (OpenSSL).
3. CertificateMetadata::fromPem() iz certifikata izvlači metapodatke: serijski broj, subject, issuer, rok valjanosti (valid_from/valid_to), fingerprint.
4. **Pohrana ključa:** privatni ključ i certifikat zapisuju se na **gitignoran PKI disk** pod parties/{oib}/{serial}.key i .crt.
5. **Invarijanta „samo jedan aktivan”:** u jednoj transakciji prethodni Active certifikat stranke prelazi u Superseded, a novi se kreira kao Active.
6. Vraća se 201 Created s CertificateResource.

Posljedice: novi red u certificates (status active); eventualni prethodni aktivni postaje superseded; privatni ključ pohranjen na PKI disku (nikad se ne vraća kroz API).

Alternativni tokovi i greške:

- Pogrešna lozinka ili neispravan PKCS#12 → 422 („Unable to read PKCS#12...”).
- PEM bez valjanog X.509 certifikata ili bez čitljivog privatnog ključa → 422.

Sigurnosna napomena: CertificateResource izlaže **samo javni certificate_pem** i metapodatke. Privatni ključ nikad nije dio odgovora.

4.1.4 UC-A4 — Pregled, dohvat i opoziv certifikata

Akteri	Administrator posrednika
Cilj	Vidjeti certifikate stranke, dohvatiti pojedini, opozvati certifikat.
Endpointi	GET /parties/{party}/certificates, GET .../{certificate}, DELETE .../{certificate}
Kod	CertificateController@index / show / destroy

Glavni tokovi:

- **Pregled** (index): lista certifikata stranke, najnoviji prvi.
- **Dohvat** (show): pojedini certifikat (scoped binding veže {certificate} uz {party}).
- **Opoziv** (destroy): certifikatu se status postavlja na **revoked** i vraća se 204 No Content. Opoziv je „meki” — red se ne briše, čime ostaje revizijski trag, a potpisani dokumenti nastali dok je bio aktivan i dalje su provjerivi.

4.1.5 UC-A5 — Otkrivanje primatelja (MPS lookup)

Akteri	Drugi posrednik (peer)
Cilj	Saznati kako (na kojem AS4 endpointu) dostaviti račun za zadani OIB.
Endpoint	GET /mps/participants/{oib}
Kod	MpsParticipantController@show

Koncept: MPS (*Metapodatkovni servis*) ovog posrednika objavljuje koje stranke opslužujemo. Nema vlastitu tablicu — odgovor je **izveden** iz **parties** tablice i konfiguracije.

Glavni tok:

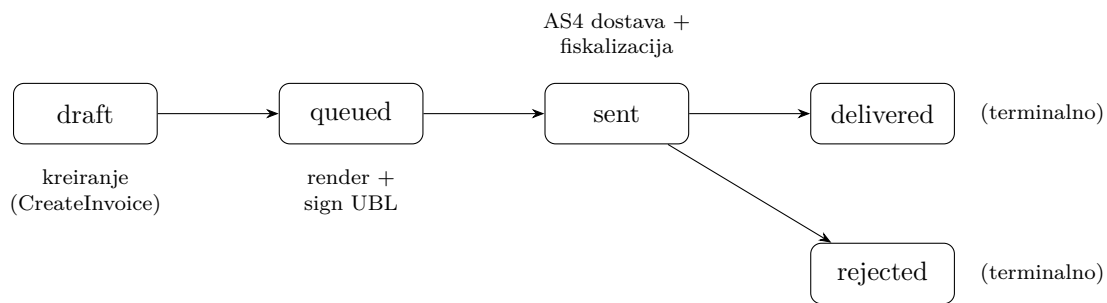
1. Peer (ili `AmsMpsPeerEndpointResolver` drugog posrednika) traži OIB.
2. Ako stranku s tim OIB-om opslužujemo (**parties** sadrži OIB) → vraća se JSON { `oib`, `as4_endpoint` }, gdje je `as4_endpoint` naš AS4 inbox iz konfiguracije.
3. Inače → 404.

Veza s discoveryjem: na strani pošiljatelja, `AmsMpsPeerEndpointResolver` prvo pita AMS (nacionalni adresar) koji MPS opslužuje traženi OIB, zatim taj MPS za konkretan AS4 endpoint, uz **fallback** na statičku `OIB=URL` mapu iz konfiguracije (`ConfigPeerEndpointResolver`). Detaljnije u cjelini B (AS4 dostava).

4.2 B. Izlazni račun

Ovo je glavni tok sustava (kut 2 — posrednik pošiljatelj). Dobavljačev ERP kreira račun, posrednik ga gura kroz životni ciklus, generira i potpisuje UBL, fiskalizira ga prema CIS-u i dostavlja preko AS4 primateljevom posredniku.

Životni ciklus izlaznog računa



Matrica dopuštenih prijelaza (`InvoiceStatus::allowedTransitions`):

Iz \ U	draft	queued	sent	received	delivered	rejected
draft	—	✓				
queued		—	✓			
sent			—		✓	✓
received				—	✓	✓
delivered					terminalno	
rejected						terminalno

received je ulazna grana (cjelina C). **delivered** i **rejected** su terminalni — iz njih nema prijelaza. Svaki nedopušteni prijelaz baca `InvalidInvoiceTransitionException`.

Side-effecti su vezani uz **ciljno stanje + smjer** (`TransitionInvoiceStatus`):

Prijelaz	Smjer	Side-effect
→ queued	outbound	renderiraj + potpiši + validiraj UBL, pohrani ga (<code>StoreInvoiceUbl</code>)
→ sent	outbound	AS4 dostava (<code>SubmitAs4Delivery</code>) i fiskalizacija (<code>SubmitFiscalization</code>)
→ delivered	inbound	fiskalizacija sa strane primatelja (cjelina C)

4.2.1 UC-B1 — Kreiranje izlaznog računa

Akteri	ERP dobavljača
Cilj	Unijeti novi račun s stavkama; sustav izračuna iznose i sprema ga kao draft .
Endpoint	POST /invoices
Kod	<code>InvoiceController@store</code> → <code>CreateInvoice</code>

Preduvjeti: dobavljač i kupac postoje kao stranke (**parties**).

Glavni tok:

- ERP šalje zaglavlje (`supplier_oib`, `buyer_oib`, `invoice_number`, `issue_date`, opc. `due_date`, `direction`, opc. `currency`) i polje `lines` (≥ 1 stavka).
- `StoreInvoiceRequest` validira:
 - oba OIB-a valjana (`Oib`) i **postoje** (`exists:parties,oib`); kupac **različit** od dobavljača,
 - `invoice_number` **jedinstven po dobavljaču** (kombinacija `supplier` + broj),

- `due_date` (ako je dan) `after_or_equal issue_date`,
 - svaka stavka: `description`, `quantity > 0`, `unit_price > 0`, `vat_rate` 0–100, `vat_category` (S/Z/E), `kpd_code` **točno 6 znakova** (obavezan), opc. `unit_code` (3 znaka).
3. `CreateInvoice` u **transakciji**: razriješi dobavljača/kupca po OIB-u, za svaku stavku iz računa `line_total = quantity × unit_price` i `line_tax = line_total × vat_rate / 100` (svi izračuni preko `bcmath`, fiksna decimalna preciznost — bez float grešaka), te zbroji `net_amount`, `tax_amount`, `total_amount`.
 4. Račun se sprema sa statusom **draft** (status nije mass-assignable — **Draft** je rodno stanje), zatim se kreiraju stavke. `unit_code` default je H87 (komad).
 5. Vraća se 201 **Created** s `InvoiceResource` (s učitanim `supplier`, `buyer`, `lines`).

Posljedice: novi red u `invoices` (status **draft**) + redovi u `invoice_lines`. Iznosi su izvedeni na poslužitelju — ERP ih ne diktira.

Greške: validacijske → 422; nepostojeći OIB → 422 (preko `exists`).

4.2.2 UC-B2 — Pregled i filtriranje računa

Akteri	ERP / administrator
Endpoint	GET /invoices?status=&direction=&supplier_oib=&buyer_oib=
Kod	InvoiceController@index (ListInvoicesRequest)

Glavni tok: paginirana lista (najnoviji prvi), s opcionalnim filtrima po `status`, `direction`, `supplier_oib`, `buyer_oib`. Učitava `supplier`, `buyer`, `lines`.

4.2.3 UC-B3 — Dohvat računa

Endpoint	GET /invoices/{invoice}
Kod	InvoiceController@show

Vraća pojedini račun s relacijama; nepostojeći → 404.

4.2.4 UC-B4 — Preuzimanje UBL XML-a

Akteri	ERP / administrator
Cilj	Dohvatiti UBL prikaz računa (potpisani konačni, ili draft pretpregled).
Endpoint	GET /invoices/{invoice}/xml
Kod	InvoiceXmlController@show → UblDocumentRenderer

Glavni tok:

1. Ako račun **ima pohranjeni UBL** (`ubl_xml_path` postavljen, dokument se streama s diska) → vrati ga (`Content-Type: application/xml`). To su **točni potpisani bajtovi**.
2. Inače, ako je račun **draft + outbound** → renderiraj **nepotpisani draft** UBL on-the-fly (`renderer->draft()`) kao pretpregled mapiranja.
3. Inače → 404 (npr. inbound bez pohranjenog dokumenta).

Byte-fidelity: potpisani UBL pohranjuje se i vraća **nepromijenjen**. Potpis (XML-DSig) računa se nad DOM-om, pa bi ponovno serijaliziranje/„uljepšavanje” ubacilo bjeline koje digesti nisu vidjeli i tiho slomilo verifikaciju. (Detalji u poglavlju 7.)

4.2.5 UC-B5 — Prijelaz statusa (životni ciklus)

Akteri	ERP / administrator
Cilj	Pomaknuti račun kroz životni ciklus; pritom se okidaju UBL/dostava/fiskalizacija.
Endpoint	PATCH /invoices/{invoice}/status
Kod	InvoiceStatusController@update → TransitionInvoiceStatus

Glavni tok:

1. ERP šalje ciljni status (`UpdateInvoiceStatusRequest` ga validira protiv enuma).
2. `TransitionInvoiceStatus` **prvo provjeri** je li prijelaz dopušten — ako nije, `InvalidInvoiceTransitionException` (ništa se ne mijenja).
3. Ako ciljno stanje traži UBL (`queued + outbound`), **renderira i potpiše prije** promjene statusa — neispravan dokument (XSD/Schematron) baca `InvoiceValidationException` i račun ostaje u zatečenom stanju.
4. Status se promijeni (`transitionTo`, koji **ponovno** čuva pravila kao jedini siguran put).
5. Pohrani se potpisani UBL (ako je generiran).
6. Okidaju se side-effecti prema tablici gore:
 - → `sent` (`outbound`): **AS4 dostava i fiskalizacija**.
7. Vraća se 200 OK s ažuriranim `InvoiceResource`.

Gljučna odluka — decoupling: ako AS4 dostava ili fiskalizacija bace iznimku, **prijelaz se NE poništava**. Greška se trajno zapiše na pripadni red (`as4_messages / fiscal_messages`) i izloži kroz resource, a radnja se ponavlja preko UC-B6/UC-B7.

Greške: nedopušten prijelaz → iznimka (409/422 ovisno o mapiranju); nevaljan UBL → 422 s izvještajem validacije.

4.2.6 UC-B6 — Fiskalizacija računa (ponovni pokušaj / ručno)

Akteri	ERP / administrator (ili automatski iz UC-B5)
Cilj	Prijaviti račun CIS-u i dobiti potvrdu (identifikator poruke, <code>service_message_id</code>).
Endpoint	POST /invoices/{invoice}/fiscalize
Kod	InvoiceFiscalizationController@store → SubmitFiscalization

Glavni tok:

1. Odredi se **reporter OIB** (`reporterOib()`): za `outbound` to je dobavljač, za `inbound` kupac.
2. **Idempotentnost:** ako već postoji `accepted` fiskalna poruka za taj reporter → `SubmissionOutcome::AlreadyTerminal` → 409 Conflict („already accepted”); ne šalje se ponovno.
3. `FiscalMessageBuilder` izgradi fiskalni XML, koji se **potpiše** potpisnim vjerodajnicama te stranke (`InvoiceSigner + PartySigningCredentials->forOib`).
4. Kreira se / ažurira fiskalna poruka u stanje **requested** (`request_xml`, `submitted_at`).
5. Poziva se `FiscalizationService->fiscalize(xml)` (HTTP prema mock CIS-u):
 - **uspjeh** → poruka u `accepted`, spremi se `service_message_id`, `match_status`, `settled_at`; vrati 200 OK s resource-om.
 - **greška** (`FiscalizationServiceException`) → poruka u **error** s `error_code/ error_message/settled_at`; baci se `FiscalizationException`.

Posljedice: red u `fiscal_messages` (stanje `requested→accepted/error`). Kod ponovnog poziva postojeća se poruka **ponovno koristi** (`upsert`), ne stvara se duplikat.

4.2.7 UC-B7 — AS4 dostava primatelju (ponovni pokušaj / ručno)

Akteri	ERP / administrator (ili automatski iz UC-B5)
Cilj	Dostaviti potpisani UBL primateljevom posredniku preko AS4.
Endpoint	POST /invoices/{invoice}/deliver
Kod	InvoiceDeliveryController@store → SubmitAs4Delivery

Glavni tok:

1. **Idempotentnost:** ako već postoji **acknowledged** izlazna AS4 poruka → **AlreadyTerminal** → 409 **Conflict** („already acknowledged”).
2. Odrede se **senderOib** (dobavljač) i **recipientOib** (kupac); dohvati se pohranjeni **potpisani UBL** (**ubl_xml**). Ako ga nema (npr. fixture bez generiranja) → **Skipped** (nema što dostaviti).
3. **As4DeliveryService->send(ubl, sender, recipient):**
 - razriješi primateljev AS4 endpoint (peer discovery — vidi dolje),
 - izgradi i potpiše AS4 envelope, pošalje ga HTTP-om, primi **receipt**.
4. **Uspjeh:** kreira se izlazni red u **as4_messages** u stanju **acknowledged** (**message_id**, **ref_to_message_id**, **envelope** + receipt XML, **sent_at**, **acknowledged_at**).
5. **Greška (As4DeliveryException):**
 - ako je envelope već bio izgrađen → zapiše se **as4_messages** red u stanju **error** (s envelopeom i **error_code/error_message**) radi revizije,
 - ako je greška **prije** gradnje envelopea (npr. nepoznat primatelj) → ništa se ne bilježi; baca se **As4DeliveryFailedException**.

Peer discovery: primateljev endpoint razrješava **AmsMpsPeerEndpointResolver** — prvo upita **AMS** koji MPS opslužuje traženi OIB, pa taj **MPS** za AS4 endpoint (usp. UC-A5), uz **fallback** na statičku **OIB=URL** mapu iz konfiguracije (**ConfigPeerEndpointResolver**). Tako sustav radi i bez živog AMS-a.

4.3 C. Ulazni račun

Druga strana razmjene (kut 3 — posrednik primatelj). Posrednik prima tuđi račun — ili **izravno od ERP-a** (npr. testiranje, isti posrednik na obje strane), ili **preko AS4** od drugog posrednika — validira ga, **provjerava potpis**, sprema kao **received** i dalje ga obrađuje (dostava kupcu + fiskalizacija sa strane primatelja → **sravnjivanje**).

Rodno stanje ulaznog računa je received (ne draft). Dalje ide **received** → **delivered** (ili **rejected**), gdje **delivered** znači da je posrednik predao račun kupčevom ERP-u i da je kupac sad obavezan fiskalizirati.

4.3.1 UC-C1 — Prijem računa izravno iz ERP-a

Akteri	ERP (pošiljatelj UBL-a)
Cilj	Zaprimiti gotov UBL račun, provjeriti ga i upisati kao ulazni.
Endpoint	POST /invoices/inbound (tijelo = sirovi UBL XML)
Kod	InboundInvoiceController@store → UblValidator + UblParser + ReceiveInbound

Glavni tok:

1. Tijelo zahtjeva je **sirovi UBL XML**.

2. **Validacija sheme:** UblValidator->validate() (XSD + Schematron / HR-CIUS). Neispravan dokument → InvoiceValidationException → 422.
3. UblParser->parse() pretvara XML u ParsedInvoice DTO (stranke, broj, datumi, iznosi, stavke).
4. ReceiveInbound->execute(parsed, rawXml):
 - **Provjera potpisa** (assertSignatureValid): dokument mora nositi **provjerljiv potpis** — digest se podudara (nema neovlaštene izmjene) i certifikat se lančano veže na **povjerljivi CA** (SignatureVerifier + TrustStore). Neuspjeh → 422.
 - U **transakciji**: dobavljač se po potrebi **auto-kreira** (firstOrCreate po OIB-u iz dokumenta), a **kupac mora već biti registriran** kod ovog posrednika — inače buyer-not-registered → 422.
 - **Idempotentnost**: ako već postoji ulazni račun (isti dobavljač + kupac + broj + inbound) → vrati postojeći (200), bez dupliciranja.
 - Inače kreira Invoice sa statusom **received**, pohrani **sirovi UBL** verbatim (StoreInvoiceUbl) i kreira stavke iz parsiranog dokumenta.
5. Vraća 201 Created (novi) ili 200 OK (već postojao) s InvoiceResource.

Posljedice: ulazni račun (received) + pohranjeni UBL + (po potrebi) novi dobavljač.

4.3.2 UC-C2 — Prijem računa preko AS4 (inter-posrednička razmjena)

Akteri	Drugi posrednik (peer access point)
Cilj	Zaprimiti AS4 poruku s UBL teretom, vratiti AS4 receipt ili error.
Endpoint	POST /as4/inbox (tijelo = AS4/SOAP envelope)
Kod	As4InboxController@store → ReceiveAs4Message

Ovo je AS4 protokolni endpoint — uvijek vraća **AS4 envelope** (application/soap+xml), bilo **receipt** (HTTP 200) bilo **error** (HTTP 400) s EBMS:* kodom.

Glavni tok:

1. **Parsiranje + XSD validacija envelopea** (as4-envelope.xsd). Loše oblikovan/nevaljan → error EBMS:0009.
2. **Ekstrakcija metapodataka** iz zaglavlja: messageId, fromOib, toOib.
3. **Provjera WS-Security potpisa** access pointa na envelopeu (digest + lanac do povjerljivog CA). Neuspjeh → EBMS:0009. (*Unutarnji UBL ima vlastiti XAdES potpis koji se provjerava kasnije, pri ingestiji.*)
4. **Idempotentnost (replay)**: ako messageId već postoji → vrati spremljeni odgovor (receipt ili error), isti HTTP status.
5. **Primatelj registriran?** Ako toOib nije naša stranka → error EBMS:0005.
6. Zapiše se ulazna AS4 poruka (as4_messages, stanje **received**).
7. **Ingestija UBL tereta**:
 - izvuče se ubl:Invoice iz tijela envelopea,
 - UblValidator (HR-CIUS) — neuspjeh → EBMS:0004,
 - UblParser + ReceiveInbound (isti tok kao UC-C1, uključujući provjeru XAdES potpisa i kreiranje ulaznog računa); bilo koja greška → EBMS:0004, AS4 poruka u stanje **error**.
8. **Uspjeh**: izgradi se AS4 **receipt**, AS4 poruka prelazi u **delivered** i veže se uz kreirani invoice_id; vrati se receipt (HTTP 200).

Posljedice: red u as4_messages (received → delivered/error); kod uspjeha i ulazni Invoice (received). Pošiljatelj na drugoj strani na temelju receipta svoju izlaznu AS4 poruku označi acknowledged (usp. UC-B7).

Mapiranje grešaka (ebMS): EBMS:0009 (envelope/potpis), EBMS:0005 (nepoznat primatelj), EBMS:0004 (neispravan UBL teret).

4.3.3 UC-C3 — Predaja kupcu i fiskalizacija sa strane primatelja (sraunjivanje)

Akteri	ERP kupca / administrator
Cilj	Predati zaprimljeni račun kupcu i fiskalizirati ga sa strane primatelja.
Endpoint	PATCH /invoices/{invoice}/status (received → delivered)
Kod	TransitionInvoiceStatus → SubmitFiscalization (reporter = kupac)

Glavni tok:

1. Ulazni račun (**received**) prelazi u **delivered** — trenutak kad posrednik predaje račun kupčevom ERP-u i kupac postaje obvezan fiskalizirati.
2. Side-effect (inbound + delivered): **fiskalizacija sa strane primatelja** (SubmitFiscalization, reporter OIB = **kupac**). Isti mehanizam kao UC-B6.
3. CIS uparuje kupčevu prijavu s ranijom dobavljačevom (ako postoji) i vraća **match_status**:
 - **matched** — dobavljač je već prijavio iste iznose,
 - **mismatch** — dobavljačeva prijava ima različite iznose,
 - **pending** — dobavljač još nije prijavio.

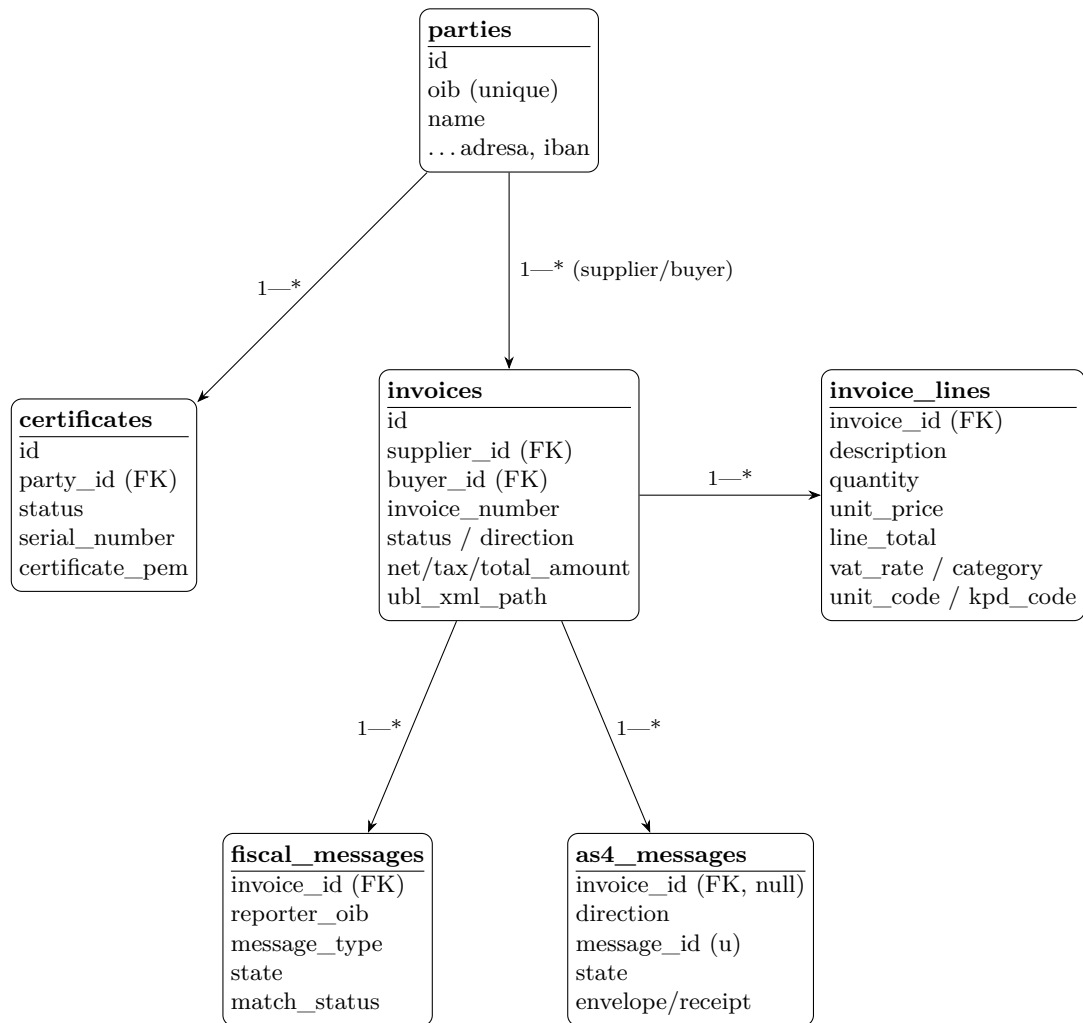
Sraunjivanje (uparivanje) i živi match_status: posrednik pri prijavi pamti samo ono što mu je CIS tada rekao. Kad kasnije stigne druga strana, CIS interno prebaci oba zapisa u **matched/mismatch**. Da bi API uvijek pokazao **trenutnu istinu**, InvoiceResource pri čitanju **ponovno pita** CIS (FiscalizationService::lookupMatch()) i pada na pohranjenu vrijednost ako upit ne uspije. Tako npr. dobavljačev izlazni račun pokaže **pending** → **matched** nakon što kupac fiskalizira, bez ikakvih background jobova ili webhookova.

Puni round-trip (jedna instanca, oba posrednika): POST /invoices (draft) → → queued (UBL) → → sent (dobavljačeva fiskalizacija = **pending** + AS4 dostava) → POST /invoices/inbound ili POST /as4/inbox (ulazni **received**) → → **delivered** (kupčeva fiskalizacija) → oba računa pokazuju **matched**.

5 Model podataka

Baza je relacijska, upravljana Eloquent migracijama. Šest domenskih tablica (uz Laravelove sistemske: **users**, **cache**, **jobs**).

5.1 ER dijagram



Relacije (Eloquent):

- Party 1—* Invoice (dvije veze: `supplier_id`, `buyer_id`)
- Party 1—* Certificate (cascade delete)
- Invoice 1—* InvoiceLine (cascade delete)
- Invoice 1—* FiscalMessage
- Invoice 1—* As4Message (FK nullable — error prije vezivanja računa)

5.2 parties — stranke

Stupac	Tip	Napomena
id	bigint PK	
oib	string(11) unique	identifikator subjekta
name	string	naziv
is_vat_registered	bool (default false)	obveznik PDV-a
address_line, city	string	adresa
postcode	string(5)	poštanski broj
country_code	string(2), default HR	ISO 3166-1 alpha-2
iban	string, nullable	
timestamps		

5.3 invoices — računi

Stupac	Tip	Napomena
id	bigint PK	
supplier_id	FK → parties	dobavljač
buyer_id	FK → parties	kupac
invoice_number	string	jedinstven po dobavljaču (validacija)
issue_date	date	datum izdavanja
due_date	date, nullable	dospijeće
status	string	InvoiceStatus enum
direction	string	InvoiceDirection (outbound/inbound)
currency	string(3), default EUR	
net_amount, tax_amount, total_amount	decimal(12,2)	izračunato na serveru
ubl_xml_path	string, nullable	putanja do UBL-a na disku (ne sadržaj)
timestamps		

ubl_xml (sadržaj) nije stupac — to je read-only accessor koji streama dokument s diska po
ubl_xml_path (vidi UC-B4 i napomenu o byte-fidelity u poglavlju 7).

5.4 invoice_lines — stavke računa

Stupac	Tip	Napomena
id	bigint PK	
invoice_id	FK → invoices (cascade)	
description	string	
quantity	decimal(10,3)	
unit_price	decimal(12,2)	
line_total	decimal(12,2)	quantity × unit_price
vat_rate	decimal(5,2)	stopa %
vat_category	string(1)	VatCategory (S/Z/E)
unit_code	string(3), default H87	jedinica mjere (UN/ECE)
kpd_code	string(6), nullable	KPD 2025 (obavezno na ulazu API-ja)

5.5 fiscal_messages — fiskalne poruke (CIS)

Stupac	Tip	Napomena
id	bigint PK	
invoice_id	FK → invoices	
reporter_oib	string(11)	tko prijavljuje (dobavljač ili kupac)
message_type	string	FiscalMessageType (fis)
state	string	FiscalMessageState (requested/accepted/error)
service_message_id	string, nullable	identifikator poruke koji vraća CIS
match_status	string, nullable	MatchStatus (pending/matched/mismatch)
error_code, error_message	string/text, nullable	
request_xml, response_xml	text, nullable	revizijski trag
submitted_at, settled_at	timestamp, nullable	
unique		(invoice_id, reporter_oib, message_type)

Unique ključ osigurava da svaka strana (reporter) ima točno jednu FIS poruku po računu — temelj idempotentnog upserta iz UC-B6.

5.6 as4_messages — AS4 poruke (transport)

Stupac	Tip	Napomena
id	bigint PK	
invoice_id	FK → invoices, nullable	null kod greške prije vezivanja
direction	string	As4MessageDirection (outbound/inbound)
message_id	string(64) unique	ebMS MessageId
ref_to_message_id	string(64), nullable	referenca na receipt
from_oib, to_oib	string(11)	
state	string	As4MessageState
error_code, error_message	string/text, nullable	
envelope_xml	text	poslani/primljeni envelope
receipt_xml	text, nullable	receipt/error envelope
sent_at, acknowledged_at, received_at	timestamp, nullable	

message_id je **unique** → temelj replay-idempotentnosti AS4 prijema (UC-C2).

5.7 certificates — potpisni certifikati stranaka

Stupac	Tip	Napomena
id	bigint PK	
party_id	FK → parties (cascade)	
status	string, default active	CertificateStatus (active/superseded/revoked)
serial_number	string	serijski broj X.509
subject, issuer	string	
valid_from, valid_to	timestamp	rok valjanosti
certificate_pem	text	javni certifikat (sigurno za pohranu/izlaz)
private_key_path	string	putanja do ključa na PKI disku (nikad se ne serijalizira)
fingerprint	string(64), index	
index		(party_id, status) — pogon „single active” invarijante

6 API referenca

Sve rute imaju prefiks `/api`. Format je JSON, osim UBL/AS4 endpointa koji koriste XML. Greške validacije vraćaju standardni Laravel 422 oblik (vidi 6.14).

▮ OIB-ovi u primjerima su **ilustrativni**; u praksi moraju proći kontrolnu znamenku (ISO 7064).

Pregled endpointa

Metoda	Putanja	Opis	Use case
POST	<code>/api/parties</code>	Registracija stranke	UC-A1
GET	<code>/api/parties/{party}</code>	Dohvat stranke	UC-A2
GET	<code>/api/parties/{party}/certificates</code>	Lista certifikata	UC-A4
POST	<code>/api/parties/{party}/certificates</code>	Učitavanje certifikata	UC-A3
GET	<code>/api/parties/{party}/certificates/{certificate}</code>	Dohvat certifikata	UC-A4
DELETE	<code>/api/parties/{party}/certificates/{certificate}</code>	Opoziv certifikata	UC-A4
GET	<code>/api/mps/participants/{oib}</code>	MPS discovery	UC-A5
POST	<code>/api/invoices</code>	Kreiranje izlaznog računa	UC-B1
GET	<code>/api/invoices</code>	Lista/filtriranje računa	UC-B2
GET	<code>/api/invoices/{invoice}</code>	Dohvat računa	UC-B3
GET	<code>/api/invoices/{invoice}/xml</code>	UBL XML računa	UC-B4
PATCH	<code>/api/invoices/{invoice}/status</code>	Prijelaz statusa	UC-B5 / UC-C3
POST	<code>/api/invoices/{invoice}/fiscalize</code>	Fiskalizacija	UC-B6
POST	<code>/api/invoices/{invoice}/deliver</code>	AS4 dostava	UC-B7
POST	<code>/api/invoices/inbound</code>	Prijem računa iz ERP-a	UC-C1
POST	<code>/api/as4/inbox</code>	Prijem AS4 poruke	UC-C2

6.1 POST /api/parties — registracija stranke

Zahtjev:

```
{
  "oib": "12345678903",
```

```

    "name": "Dobavljač d.o.o.",
    "is_vat_registered": true,
    "address_line": "Ilica 1",
    "city": "Zagreb",
    "postcode": "10000",
    "country_code": "HR",
    "iban": "HR1210010051863000160"
  }

```

Odgovor — 201 Created:

```

{
  "data": {
    "id": 1,
    "oib": "12345678903",
    "name": "Dobavljač d.o.o.",
    "is_vat_registered": true,
    "address_line": "Ilica 1",
    "city": "Zagreb",
    "postcode": "10000",
    "country_code": "HR",
    "iban": "HR1210010051863000160"
  }
}

```

6.2 GET /api/parties/{party} — dohvat stranke

Odgovor — 200 OK: isti data oblik kao gore. Nepostojeća stranka → 404.

6.3 POST /api/parties/{party}/certificates — učitavanje certifikata

Dva načina slanja (vidi UC-A3):

(a) PEM string:

```

{
  "certificate_pem": "-----BEGIN CERTIFICATE-----\nMIID...\n-----END  

  ↪ CERTIFICATE-----\n-----BEGIN PRIVATE KEY-----\nMIIE...\n-----END PRIVATE  

  ↪ KEY-----",
  "password": null
}

```

(b) PKCS#12 datoteka: multipart/form-data s poljem certificate (.p12/.pfx) i opcionalnim password.

Odgovor — 201 Created:

```

{
  "data": {
    "id": 5,
    "party_id": 1,
    "status": "active",

```

```

    "serial_number": "0A1B2C3D",
    "subject": "CN=Dobavljač d.o.o., O=..., OIB=12345678903",
    "issuer": "CN=eRakun Test FINA CA",
    "valid_from": "2026-01-01T00:00:00.000000Z",
    "valid_to": "2027-01-01T00:00:00.000000Z",
    "fingerprint": "9f2a...c7",
    "certificate_pem": "-----BEGIN CERTIFICATE-----\nMIID...\n-----END
    ↪ CERTIFICATE-----"
  }
}

```

Privatni ključ **nije** dio odgovora. Greška (kriva lozinka / neispravan materijal) → 422.

6.4 GET /api/parties/{party}/certificates — lista certifikata

Odgovor — 200 OK: { "data": [{ ...certifikat... }, ...] } (najnoviji prvi).

6.5 DELETE /api/parties/{party}/certificates/{certificate} — opoziv

Odgovor — 204 No Content. Status certifikata postaje revoked (red se ne briše).

6.6 GET /api/mps/participants/{oib} — MPS discovery

Odgovor — 200 OK:

```

{
  "oib": "98765432106",
  "as4_endpoint": "https://receiver.erakun.test/api/as4/inbox"
}

```

Ako OIB nije među opsluženim strankama → 404.

6.7 POST /api/invoices — kreiranje izlaznog računa

Zahtjev:

```

{
  "supplier_oib": "12345678903",
  "buyer_oib": "98765432106",
  "invoice_number": "2026-001",
  "issue_date": "2026-06-08",
  "due_date": "2026-06-23",
  "direction": "outbound",
  "currency": "EUR",
  "lines": [
    {
      "description": "Konzultantske usluge",
      "quantity": 10,
      "unit_price": 100.00,
      "vat_rate": 25,
      "vat_category": "S",

```

```

        "unit_code": "H87",
        "kpd_code": "620100"
    }
]
}

```

Odgovor — 201 Created: (puni InvoiceResource, vidi 6.9) Iznosi (net_amount 1000.00, tax_amount 250.00, total_amount 1250.00) računaju se na serveru.

6.8 GET /api/invoices — lista i filtriranje

Filteri (svi opcionalni): status, direction, supplier_oib, buyer_oib. Paginirano.

Odgovor — 200 OK:

```

{
  "data": [ { "id": 1, "invoice_number": "2026-001", "status": "sent", "...":
↪ "..."} ],
  "links": { "first": "...", "last": "...", "prev": null, "next": null },
  "meta": { "current_page": 1, "per_page": 15, "total": 1 }
}

```

6.9 GET /api/invoices/{invoice} — dohvat računa

Odgovor — 200 OK (puni oblik s delivery i fiscalization blokovima):

```

{
  "data": {
    "id": 1,
    "invoice_number": "2026-001",
    "supplier": { "id": 1, "oib": "12345678903", "name": "Dobavljač d.o.o.",
↪ "...": "..."},
    "buyer": { "id": 2, "oib": "98765432106", "name": "Kupac d.o.o.", "...": "..."}
↪ },
    "issue_date": "2026-06-08",
    "due_date": "2026-06-23",
    "status": "sent",
    "direction": "outbound",
    "currency": "EUR",
    "net_amount": "1000.00",
    "tax_amount": "250.00",
    "total_amount": "1250.00",
    "lines": [
      {
        "description": "Konzultantske usluge",
        "quantity": "10.000",
        "unit_price": "100.00",
        "line_total": "1000.00",
        "vat_rate": "25.00",
        "vat_category": "S",
        "unit_code": "H87",
        "kpd_code": "620100"
      }
    ]
  }
}

```



```

    ],
    "delivery": {
      "state": "acknowledged",
      "message_id": "a1b2...@erakun",
      "peer_message_id": "c3d4...@erakun",
      "sent_at": "2026-06-08T10:00:00Z",
      "acknowledged_at": "2026-06-08T10:00:01Z",
      "error": null
    },
    "fiscalization": {
      "state": "accepted",
      "service_message_id": "FIS-2026-0001",
      "match_status": "matched",
      "error_code": null,
      "error_message": null,
      "submitted_at": "2026-06-08T10:00:00Z",
      "settled_at": "2026-06-08T10:00:01Z"
    }
  }
}

```

delivery i fiscalization su null dok pripadne poruke ne postoje. match_status se dohvaća uživo iz CIS-a pri čitanju (vidi UC-C3).

6.10 GET /api/invoices/{invoice}/xml — UBL XML

Odgovor — 200 OK, Content-Type: application/xml — potpisani UBL (ako je pohranjen) ili nepotpisani draft (za draft + outbound). Inače 404.

6.11 PATCH /api/invoices/{invoice}/status — prijelaz statusa

Zahtjev:

```
{ "status": "queued" }
```

Odgovor — 200 OK: ažurirani InvoiceResource. Nedopušten prijelaz → greška; nevaljan UBL pri → queued → 422 s izvještajem validacije.

6.12 Fiskalizacija i dostava (ručno / retry)

POST /api/invoices/{invoice}/fiscalize i POST /api/invoices/{invoice}/deliver:

- 200 OK — ažurirani InvoiceResource (vidi fiscalization / delivery blok).
- 409 Conflict — radnja je već u terminalnom stanju:

```
{ "message": "Fiscal message is already accepted." }
```

```
{ "message": "AS4 delivery is already acknowledged." }
```

6.13 Prijem računa i AS4

- `POST /api/invoices/inbound` — tijelo je **sirovi UBL XML** (`Content-Type: application/xml`). Odgovor 201 (novi) / 200 (već postojao) s `InvoiceResource`; nevaljan UBL ili potpis → 422.
- `POST /api/as4/inbox` — tijelo je **AS4/SOAP envelope**. Odgovor je AS4 envelope (`application/soap+xml`): receipt (200) ili error (400, s `EBMS:*` kodom).

6.14 Oblik validacijske greške

Standardni Laravel 422 Unprocessable Entity:

```
{
  "message": "The buyer oib field must be different from supplier oib.",
  "errors": {
    "buyer_oib": ["The buyer oib field must be different from supplier oib."],
    "lines.0.kpd_code": ["The lines.0.kpd_code field must be 6 characters."]
  }
}
```

7 Sigurnost i PKI

Potpisivanje i verifikacija u projektu su **prava kriptografija** (RSA-2048, SHA-256, ispravne X.509 ekstenzije) — jedino su **korijeni povjerenja samo-generirani** (testni PKI) umjesto pravih FINA/OpenPEPPOL korijena. Koriste se OpenSSL i `robrichards/xmlseclibs`.

7.1 Dva sloja potpisa (kao u PEPPOL-u)

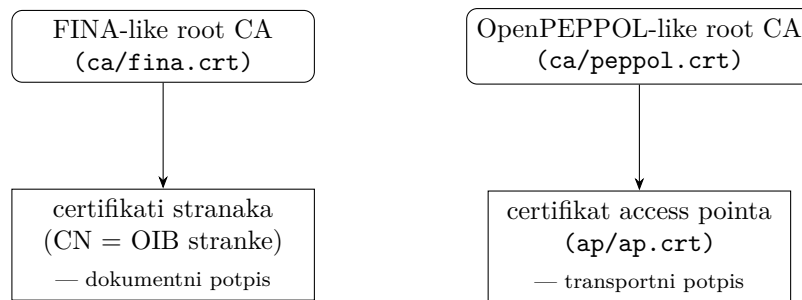
Sustav vjerno odražava PEPPOL podjelu na **dokumentni** i **transportni** sloj, sa **dva odvojena certifikata**:

Sloj	Što potpisuje	Čime	Standard	Kod
Dokumentni	UBL račun (enveloped)	certifikat stranke (FINA-like)	XAdES-B	<code>InvoiceSigner</code>
Transportni	AS4 envelope (payload)	certifikat access pointa (PEPPOL-like)	WS-Security	<code>As4EnvelopeSigner</code>

Ulazni dokument tako nosi **dva potpisa**: WS-Security potpis access pointa na envelopeu (provjerava se prvi, pri prijemu) i XAdES potpis stranke unutar UBL-a (provjerava se kasnije, pri ingestiji) — usp. UC-C2.

7.2 Testni PKI (`TestPkiGenerator`)

Hijerarhija koja se generira komandom `php artisan pki:generate`:



- **Dvije korijenske CA** (FINA-like i PEPPOL-like) — samopotpisane, RSA-2048, SHA-256, v3_ca ekstenzije, valjanost ~10 god (`pki.ca_days`).
- **Certifikat stranke** izdaje se s **FINA-like CA**; **CN = OIB** stranke (kvalificirani certifikat vezan uz porezni broj, kao prava FINA).
- **Certifikat access pointa** izdaje se s **PEPPOL-like CA**.
- **Idempotentno**: ponovno pokretanje ne dira postojeći materijal (osim `-force`), da se ne invalidiraju ključevi već ugrađeni u izdane certifikate.
- Privatni ključevi pišu se na **gitignoran PKI disk** (`storage/app/private/pki`).

Komanda `pki:generate`:

- bez opcija → osigura da CA i AP certifikat postoje;
- `-force` → regeneriraj CA i AP;
- `-parties` → izdaj aktivni potpisni certifikat svakoj stranci koja ga nema.

7.3 Potpisivanje UBL-a (`InvoiceSigner`, `XAdES-B`)

Proizvodi **enveloped XAdES-B** potpis unutar `sac:SignatureInformation` dokumenta. Potpis nosi **dvije reference**:

1. **Referenca na cijeli dokument** (`URI=""`, enveloped transform) — SHA-256 nad exclusive-C14N kanonikalizacijom (potpis se izuzme prije računanja digesta).
2. **Referenca na XAdES SignedProperties** (vezana po Id) — sadrži `SigningTime` i digest + issuer/serial potpisnog certifikata (`SigningCertificate`).

`xmlseclibs` ne gradi XAdES ni drugu referencu sam, pa se `QualifyingProperties/SignedProperties` ručno grade i dodaju kao `ds:Object` prije potpisivanja. Potpisni algoritam je **RSA-SHA256** nad exclusive-C14N `SignedInfo`; certifikat se **ugrađuje u KeyInfo** kako bi ga verifikator mogao iskoristiti bez bočnog kanala.

Byte-fidelity: `formatOutput = false` — potpis je nad in-memory DOM-om, pa se bajtovi emitiraju verbatim. Naknadno „uljepšavanje” ubacilo bi bjeline koje digesti nisu vidjeli i tiho slomilo verifikaciju. (Vidi i UC-B4.)

7.4 Potpisivanje AS4 envelopea (`As4EnvelopeSigner`, `WS-Security`)

Na transportnom sloju, envelope se potpisuje **certifikatom access pointa**: prava RSA-SHA256 `ds:Signature` unutar `wsse:Security` zaglavlja, koja referencira **payload po wsu:Id** preko exclusive-C14N. Odvojeno od XAdES potpisa unutar UBL-a — dva sloja, dva certifikata.

7.5 Verifikacija (`SignatureVerifier`)

Verifikacija je **stvarna** i radi tri provjere:

1. **Autentičnost SignedInfo:** kanonikalizira **SignedInfo** deklariranom metodom i provjeri **SignatureValue** javnim ključem iz ugrađenog certifikata (`openssl_verify`, SHA-256).
2. **Integritet referenci:** za svaku referencu **ponovno izračuna digest** iz živog dokumenta i usporedi s onim u potpisu (`hash_equals`). Svaki nesklad = sadržaj je mijenjan nakon potpisivanja → `digestMismatch`.
3. **Povjerenje u certifikat:** certifikat se mora lančano vezati na **povjerljivi CA** (`TrustStore::isIssuedByTrustedCa`) i biti **unutar roka valjanosti** (`isWithinValidityWindow`).

Verifikacija je napisana **ručno**, ne preko `xmlseclibs::validateReference()`: ta metoda odvaja potpis prije obrade referenci, što čini in-signature XAdES **SignedProperties** referencu nerazrješivom. Ručni pristup daje punu kontrolu nad time **koji** se potpis provjerava (parametar `signatureXPath` — npr. WS-Security potpis za AS4) i kako se svaka referenca kanonikalizira.

Tipovi grešaka (`SignatureVerificationException`): nedostaje potpis/certifikat, nevaljan potpis, digest mismatch, **untrusted** (lanac ne vodi do CA), **expired**. Verifikator namjerno razlikuje „untrusted” od „expired”.

7.6 Trust store (TrustStore)

Skup CA certifikata kojima eRakun vjeruje. Leaf je povjerljiv ako mu se potpis verificira protiv jednog od **dva testna korijena** (FINA-like + PEPPOL-like). Sidra se učitavaju **lijeno** (tek pri prvoj verifikaciji), pa razrješavanje verifikatora ne pukne na sustavu koji još nije generirao PKI. U produkciji bi to bili pravi FINA i OpenPEPPOL korijeni.

7.7 Razrješavanje potpisnih vjerodajnica (PartySigningCredentials)

Pri potpisivanju, vjerodajnice stranke razrješavaju se iz njenog **jedinog aktivnog certifikata** (`activeCertificate`). Ako stranka nema aktivni certifikat, baca se iznimka — **dokument nikad ne smije izaći nepotpisan**.

7.8 Sažetak sigurnosnih svojstava

- **Integritet i autentičnost računa:** XAdES-B potpis stranke; transport: WS-Security potpis AP-a.
- **Neporecivost (osnovna):** `SigningTime` + vezanje na konkretan certifikat (digest + issuer/serial).
- **Provjera povjerenja:** lanac do CA + rok valjanosti, na obje strane razmjene.
- **Zaštita tajni:** privatni ključevi nikad ne napuštaju PKI disk niti se serijaliziraju u API.
- **Svjesna granica:** korijeni povjerenja su testni; nema OCSP/CRL provjere opoziva certifikata, ni vremenskog žiga treće strane (TSA) — izvan opsega (vidi poglavlje 8).

8 Zaključak i ograničenja

8.1 Što projekt postiže

eRakun implementira **funkcionalnu jezgru informacijskog posrednika** za Fiskalizaciju 2.0, pokrivajući cijeli 4-corner tijekom razmjene eRačuna:

- **ERP integracija** (REST API) za izlazne i ulazne račune;

- **UBL 2.1 / HR-CIUS** generiranje i parsiranje, uz **XSD + Schematron** validaciju;
- **pravo digitalno potpisivanje i verifikaciju** na dva sloja (XAdES-B na dokumentu, WS-Security na transportu) s vlastitim PKI-jem i provjerom lanca povjerenja;
- **fiskalizaciju** prema mock CIS-u sa **sravnjivanjem** (matched/mismatch/pending) i živim osvježavanjem statusa;
- **AS4** razmjenu između dva posrednika s receipt/error envelopeima i ebMS kodovima;
- **dinamičko otkrivanje** primatelja preko AMS/MPS, uz fallback na konfiguraciju.

Arhitektura je dosljedna: tanki REST kontroleri, poslovna logika u Action klasama, vanjski servisi iza sučelja (zamjenjivi mock ↔ produkcija bez diranja domene), te **čvrste invarijante** (dopušteni prijelazi stanja, single-active certifikat, idempotentne radnje).

8.2 Svjesna ograničenja

Sve navedeno su **namjerne granice opsega** studentskog projekta — prikladne ovdje, ali označene da se ne prenose u nešto stvarno:

Područje	Ograničenje
Porezna / CIS PKI	Oponašano companion aplikacijom (erakun-porezna), nije pravi CIS. Samo-generirani testni korijeni umjesto pravih FINA/OpenPEPPOL certifikata.
Opoziv certifikata	Nema OCSP/CRL provjere; opoziv je samo interni status revoked .
Vremenski žig eReporting	XAdES nosi SigningTime , ali nema kvalificiranog TSA (XAdES-T i više). Samo osnovni fis tip; plaćanja/odbijanja (fis_payment/fis_reject/fis_ir) predviđeni ali neimplementirani.
Sigurnost API-ja	Nema autentikacije/autorizacije ERP klijenata, rate-limitinga ni multi-tenancyja.
Otpornost	Dostava/fiskalizacija se ponavljaju ručno (retry endpointi); nema automatskih redova/poslova.

8.3 Mogući budući rad

- Implementirati preostale eReporting tipove poruka i njihove životne cikluse.
- Dodati provjeru opoziva certifikata (OCSP/CRL) i XAdES-T (TSA žig).
- Autentikacija ERP klijenata (API tokeni/mTLS) i razdvajanje po klijentima (multi-tenancy).
- Asinkrona dostava/fiskalizacija preko redova poslova s automatskim ponavljanjem.
- Webhook iz CIS-a za **match_status** umjesto re-fetcha pri čitanju.

9 Dodatak: pokretanje i testiranje

Postavljanje i pokretanje:

```
composer setup      # install, .env, key, migrate, instalacija + kompilacija shema
php artisan pki:generate --parties # generiraj testni PKI + certifikate
↔ strankama
composer dev        # pokreni razvojni poslužitelj (php artisan serve)
```

Provjere kvalitete (uskladiti prije predaje):

composer check	# pint --test + rector --dry-run + phpstan + test (paralelno)
composer test	# samo testovi
composer lint	# automatsko formatiranje (Pint)

Dvije instance za puni round-trip: pokreni drugu instancu eRakuna kao primatelja (zaseban .env / port, vidi .env.peer) i usmjeri AS4/peer konfiguraciju jedne na drugu da račun proteče Supplier ERP → Sender AP → Receiver AP → Buyer ERP.

10 Literatura i izvori

Standardi i specifikacije

- **EN 16931-1:2017** — *Electronic invoicing — Part 1: Semantic data model of the core elements of an electronic invoice*. CEN.
- **OASIS UBL 2.1** — *Universal Business Language Version 2.1*. OASIS Standard, 2013. <https://docs.oasis-open.org/ubl/UBL-2.1.html>
- **HR-CIUS / HR-FISK 2.0** — Hrvatska prilagodba (*Core Invoice Usage Specification*) norme EN 16931; Porezna uprava, Fiskalizacija 2.0. <https://porezna.gov.hr/fiskalizacija>
- **OASIS AS4 / ebMS 3.0** — *AS4 Profile of ebMS 3.0 Version 1.0*. OASIS Standard, 2013. <https://docs.oasis-open.org/ebxml-msg/ebms/v3.0/profiles/AS4-profile/v1.0/os/AS4-profile-v1.0-os.html>
- **OASIS WS-Security** — *Web Services Security: SOAP Message Security 1.1.1*.
- **W3C XML Signature** — *XML Signature Syntax and Processing (XMLDSig)*. W3C Recommendation. <https://www.w3.org/TR/xmlsig-core/>
- **ETSI EN 319 132-1** — *XAdES digital signatures; Part 1: Building blocks and XAdES baseline signatures*. ETSI. https://www.etsi.org/deliver/etsi_en/319100_319199/31913201/01.03.01_60/en_31913201v010301p.pdf
- **KPD 2025** — Nacionalna klasifikacija proizvoda po djelatnostima; Državni zavod za statistiku.

Alati i biblioteke

- **Laravel** — PHP web framework. <https://laravel.com/docs>
- **robrichards/xmlseclibs** — PHP biblioteka za XML-DSig / XAdES. <https://github.com/robrichards/xmlseclibs>
- **OpenSSL** — kriptografske primitive (RSA, SHA-256, X.509, PKCS#12). <https://www.openssl.org/>